La charte informatique

Quel est le rôle de la charte informatique ?

Une charte informatique a pour objectif de fixer les droits et les obligations en matière d'utilisation du système d'information au sein d'une organisation. Elle doit faire prendre conscience à chaque utilisateur des enjeux en matière de sécurité et de vie privée. Elle est obligatoire dès lors qu'une organisation est amenée à traiter des données à caractère personnel.

Quelle est la structure d'une charte informatique ?

Généralement, la charte informatique se présente sous la forme d'un document à portée juridique, dans lequel des instructions sont clairement définies.

1. Objectifs

- Les usages autorisés des ressources numériques
- Les règles de sécurité en vigueur
- Les mesures de contrôle prises par l'organisation

2. Définitions claires et précises

- Définition des termes clés pour éviter les interprétations divergentes
  Exemple : définition du terme authentification

3. Objet et portée

- Sur quoi la charte porte-t-elle (droits et devoirs des utilisateurs) ?
  Exemple : Obligation de longueur du mot de passe
- A qui est-elle destiné ?

4. Usages

- Les moyens informatiques et les outils numériques mis à disposition
- Les règles et les pratiques autorisées
- Les besoins auxquels doit répondre le système d'information

5. Devoirs des utilisateurs

- Bon sens dans les pratiques
- Respect d'obligations techniques spécifiques

6. Les mesures de contrôle

- Liste des mesures de contrôle
- Conditions dans lesquelles elles sont mises en oeuvre

7. Sanctions

- Echelle de sanctions disciplinaire (proportionnelle à la gravité)
- Sanctions civiles et pénales

8. Opposabilité de la charte

- Acceptation écrite par les utilisateurs
- Annexion au règlement intérieur
- Annexion au contrat d'entreprise et au contrat des prestataires

La charte informatique

Quel est le cadre juridique pour la charte informatique ?

La charte informatique doit être portée à la connaissance des salariés. Pour cela, l'employeur peut la présenter par voie d'affichage au sein de l'entreprise ou en remettre un exemplaire à chacun des salariés. La charte informatique s'applique à l'ensemble des utilisateurs du SI, quel que soit leur statut.

Ce document peut être opposable aux salariés de l'entreprise s'il est annexé à un règlement intérieur (l'employeur n'a pas obligation de faire signer la charte) ou au contrat de travail. La date d'entrée en vigueur de la charte doit être indiquée explicitement. Si elle est postérieure à un contrat de travail, un avenant devra être établi.

L'organisation peut imposer un droit de regard et de contrôle sur les pratiques des utilisateurs, par exemple en s'appuyant sur les fichiers journaux (logs des accès et modifications des fichiers), les connexions entrantes et sortantes à Internet et à la messagerie électronique, les appels téléphoniques, etc.

Le cas particulier du nomadisme ?

L'organisation du travail dans les entreprises est aujourd'hui, bouleversée par l'avènement de nouvelles habitudes de travail liées à l'apparition du BYOD, du COPE et du CYOD :

BYOD **Bring Your Own Device**	**COPE** **Corporate Owned Parsonnaly Enabled**	**CYOD** **Choose Your Own Device**
L'employeur autorise l'utilisation des équipements privés pour exercer les missions professionnelles.	L'entreprise fournit des équipements nomades et réalise la configuration.	Le salarié choisit son matériel mais sa configuration reste à la charge de l'employeur.

Ces nouvelles habitudes de travail doivent être prises en compte dans la rédaction de la charte informatique. En effet, elles impliquent et génèrent des contraintes supplémentaires. La CNIL[1] formule des recommandations, notamment pour la protection des données personnelles.

La responsabilité de l'employeur joue également lorsque les données de l'entreprise sont stockées dans le matériel informatique personnel du salarié. L'employeur doit donc prendre les mesures nécessaires contre les risques relatifs à la confidentialité [2]des données, aux intrusions et aux virus, et les mentionner dans la charte informatique.

Entre autres, il pourra spécifier :

- Les appareils éligibles aux BYOD ;
- Les conditions d'utilisation de ces appareils ;
- Les applications utilisables via un matériel personnel ;
- Les documents accessibles par le biais d'un appareil personnel, etc.

La CNIL fournit une check-list pour créer une charte informatique qui respecte les aspects juridiques, vous la trouverez en annexe.

[1] CNIL (Commission nationale de l'Informatique et des Libertés) : Commission indépendante chargée de veiller à ce que l'informatique respecte les droits des citoyens.
[2] Confidentialité : Accessibilité à une donnée après authentification de l'utilisateur.

Annexes

Évaluer le niveau de sécurité des données personnelles de votre organisme

Avez-vous pensé à ?

Fiche		Mesure	
1	Sensibiliser les utilisateurs	Informez et sensibilisez les personnes manipulant les données	☐
		Rédigez une charte informatique et lui donner une force contraignante	☐
2	Authentifier les utilisateurs	Définissez un identifiant (*login*) unique à chaque utilisateur	☐
		Adoptez une politique de mot de passe utilisateur conforme à nos recommandations	☐
		Obligez l'utilisateur à changer son mot de passe après réinitialisation	☐
		Limitez le nombre de tentatives d'accès à un compte	☐
3	Gérer les habilitations	Définissez des profils d'habilitation	☐
		Supprimez les permissions d'accès obsolètes	☐
		Réaliser une revue annuelle des habilitations	☐
4	Tracer les accès et gérer les incidents	Prévoyez un système de journalisation	☐
		Informez les utilisateurs de la mise en place du système de journalisation	☐
		Protégez les équipements de journalisation et les informations journalisées	☐
		Prévoyez les procédures pour les notifications de violation de données à caractère personnel	☐
5	Sécuriser les postes de travail	Prévoyez une procédure de verrouillage automatique de session	☐
		Utilisez des antivirus régulièrement mis à jour	☐
		Installez un « pare-feu » (*firewall*) logiciel	☐
		Recueillez l'accord de l'utilisateur avant toute intervention sur son poste	☐
6	Sécuriser l'informatique mobile	Prévoyez des moyens de chiffrement des équipements mobiles	☐
		Faites des sauvegardes ou synchronisations régulières des données	☐
		Exigez un secret pour le déverrouillage des smartphones	☐
7	Protéger le réseau informatique interne	Limitez les flux réseau au strict nécessaire	☐
		Sécurisez les accès distants des appareils informatiques nomades par VPN	☐
		Mettez en œuvre le protocole WPA2 ou WPA2-PSK pour les réseaux Wi-Fi	☐

CNIL.
COMMISSION NATIONALE INFORMATIQUE & LIBERTÉS

8	Sécuriser les serveurs	Limitez l'accès aux outils et interfaces d'administration aux seules personnes habilitées	☐
		Installez sans délai les mises à jour critiques	☐
		Assurez une disponibilité des données	☐
9	Sécuriser les sites web	Utilisez le protocole TLS et vérifiez sa mise en œuvre	☐
		Vérifiez qu'aucun mot de passe ou identifiant ne passe dans les url	☐
		Contrôlez que les entrées des utilisateurs correspondent à ce qui est attendu	☐
		Mettez un bandeau de consentement pour les *cookies* non nécessaires au service	☐
10	Sauvegarder et prévoir la continuité d'activité	Effectuez des sauvegardes régulières	☐
		Stockez les supports de sauvegarde dans un endroit sûr	☐
		Prévoyez des moyens de sécurité pour le convoyage des sauvegardes	☐
		Prévoyez et testez régulièrement la continuité d'activité	☐
11	Archiver de manière sécurisée	Mettez en œuvre des modalités d'accès spécifiques aux données archivées	☐
		Détruisez les archives obsolètes de manière sécurisée	☐
12	Encadrer la maintenance et la destruction des données	Enregistrez les interventions de maintenance dans une main courante	☐
		Encadrez par un responsable de l'organisme les interventions par des tiers	☐
		Effacez les données de tout matériel avant sa mise au rebut	☐
13	Gérer la sous-traitance	Prévoyez une clause spécifique dans les contrats des sous-traitants	☐
		Prévoyez les conditions de restitution et de destruction des données	☐
		Assurez-vous de l'effectivité des garanties prévues (audits de sécurité, visites, etc.)	☐
14	Sécuriser les échanges avec d'autres organismes	Chiffrez les données avant leur envoi	☐
		Assurez-vous qu'il s'agit du bon destinataire	☐
		Transmettez le secret lors d'un envoi distinct et via un canal différent	☐
15	Protéger les locaux	Restreignez les accès aux locaux au moyen de portes verrouillées	☐
		Installez des alarmes anti-intrusion et vérifiez-les périodiquement	☐
16	Encadrer les développements informatiques	Proposez des paramètres respectueux de la vie privée aux utilisateurs finaux	☐
		Évitez les zones de commentaires ou encadrez-les strictement	☐
		Testez sur des données fictives ou anonymisées	☐
17	Utiliser des fonctions cryptographiques	Utilisez des algorithmes, des logiciels et des bibliothèques reconnues	☐
		Conservez les secrets et les clés cryptographiques de manière sécurisée	☐

CNIL.
COMMISSION NATIONALE
INFORMATIQUE & LIBERTÉS